

Actividad 12

File path traversal, validation of file extension with null byte bypass

Bypass de filtro — byte nulo

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-validate-file-extension-null-byte-bypass>

// FILE PATH TRAVERSAL, VALIDATION OF FILE EXTENSION WITH NULL BYTE BYPASS

OBJETIVO

Evadir una validación que exige que el nombre de archivo termine en una extensión específica, usando un byte nulo para truncar la ruta antes de esa extensión.

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

La aplicación verifica que el string de `filename` termine textualmente en la extensión esperada — pero eso ocurre a nivel de comparación de strings, antes de que el sistema operativo abra el archivo. Los sistemas de archivos basados en C interpretan el byte nulo (`%00`) como terminador de cadena: todo lo que viene después de `%00` se ignora al momento de abrir el archivo, aunque la validación de string sí lo haya "visto" completo.

PROCEDIMIENTO PASO A PASO

1. Activar Intercept on en Burp y hacer clic en un producto.
2. Interceptar la request de imagen y mandarla a Repeater.
3. Construir el payload de traversal y anexar `%00` seguido de la extensión esperada por el filtro.
4. Enviar — la validación de extensión pasa (termina en la extensión correcta como string), pero el sistema abre el archivo real antes del byte nulo.
5. Confirmar la fuga en el Response y el badge "Lab solved".

PAYLOAD UTILIZADO

```
GET /image?filename=../../../../etc/passwd%00.jpg HTTP/2
```

Para la validación de string, el filename "termina en .jpg" ✓. Para el sistema de archivos, la cadena real que se abre se corta en el byte nulo: `../../../../etc/passwd`. Ambas capas interpretan el mismo string de forma distinta, y esa discrepancia es la vulnerabilidad.

MITIGACIÓN RECOMENDADA

Actualizar a versiones de lenguaje/runtime que rechacen bytes nulos en rutas de archivo (la mayoría de los stacks modernos ya lo hacen), y nunca confiar en validaciones de extensión basadas solo en comparación de strings — validar también el tipo real del archivo (magic bytes) y la ruta canónica.

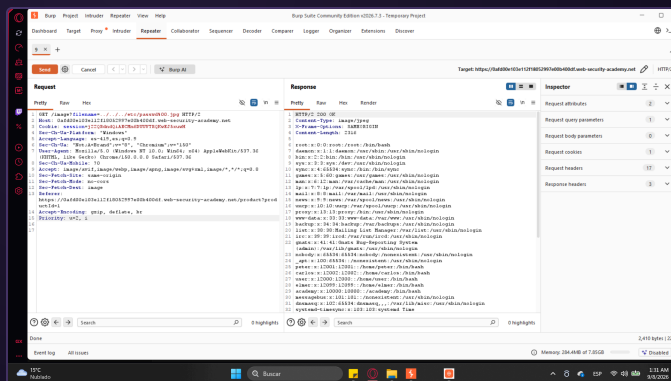


Figura 1. Request en Burp Repeater con el payload + Response con /etc/passwd

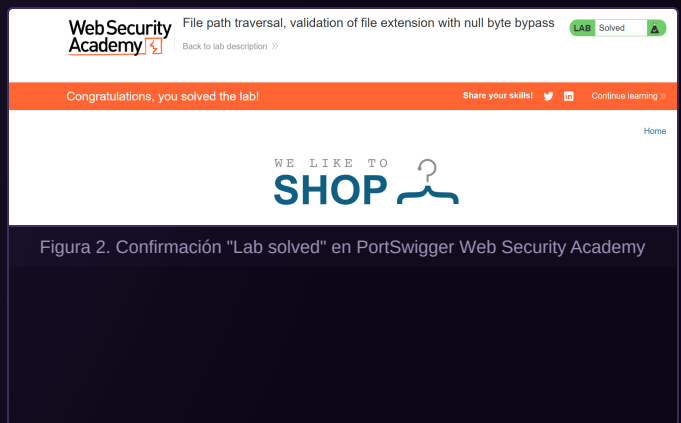


Figura 2. Confirmación "Lab solved" en PortSwigger Web Security Academy